SecureScan

Plateforme d'Analyse de Qualité et Sécurité de Code

Zouayobo DALI
Thibault LECHANTRE
Mattéo LECOHIER
Krishmini KULAKRISHNA

Contexte

CyberSafe Solutions -> startup française spécialisée en cybersécurité pour les PME

CyberSafe développe des solutions de protection et d’audit pour ses clients.

Suite à un audit de l’ANSSI (Agence Nationale de la Sécurité des Systèmes d’Information), plusieurs failles critiques ont été identifiées dans les projets internes de CyberSafe.

Ils nous demandent alors de développer SecureScan, une plateforme web interne d’analyse de la qualité et de la sécurité du code. Cette plateforme a pour but d’utiliser des outils de sécurité open source existants, d’agréger leurs résultats, de les mapper sur l’OWASP Top 10 : 2025, et de proposer des corrections automatisées.

- Aucun outil centralisé d’analyse de sécurité du code source
- Vulnérabilités d’injection (SQL, XSS) non détectées avant mise en production
- Dépendances obsolètes avec des CVE connues dans plusieurs projets
- Aucune intégration de tests de sécurité dans les pipelines CI/CD
- Pas de rapport de sécurité automatisé pour les clients 7
- Corrections de sécurité manuelles, lentes et sources d’erreurs

Diagramme

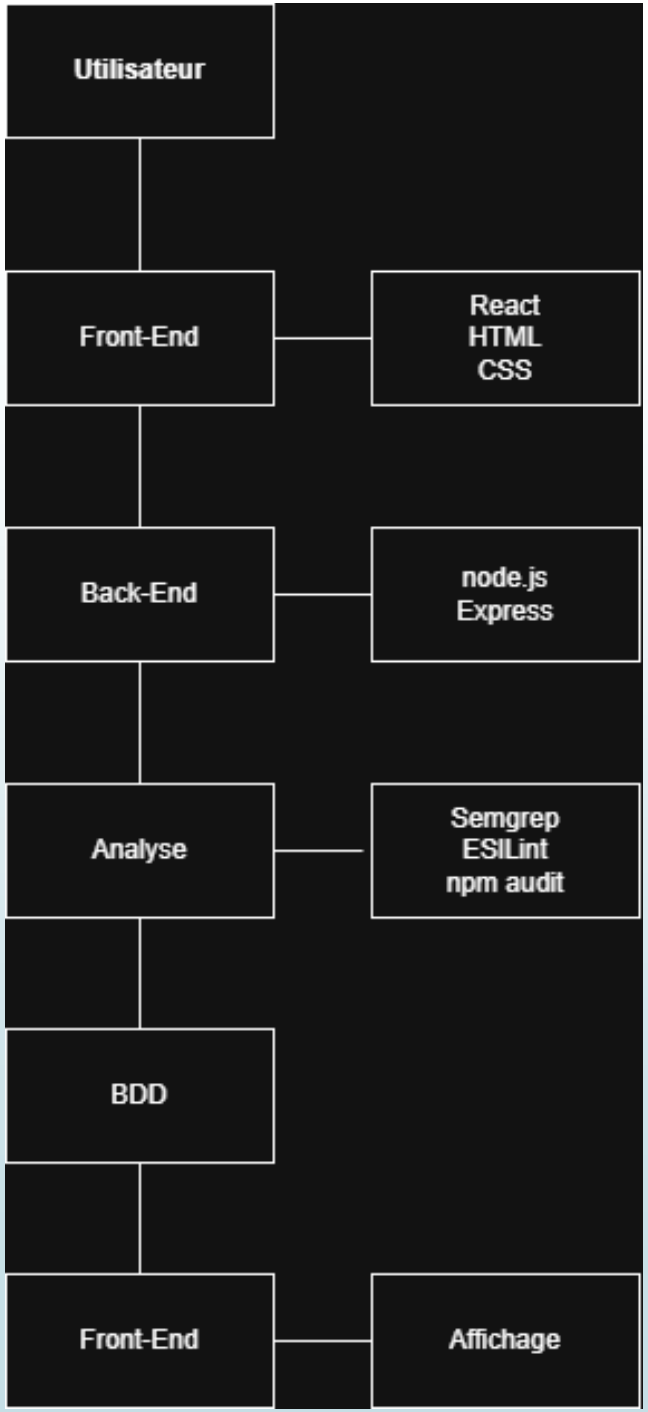
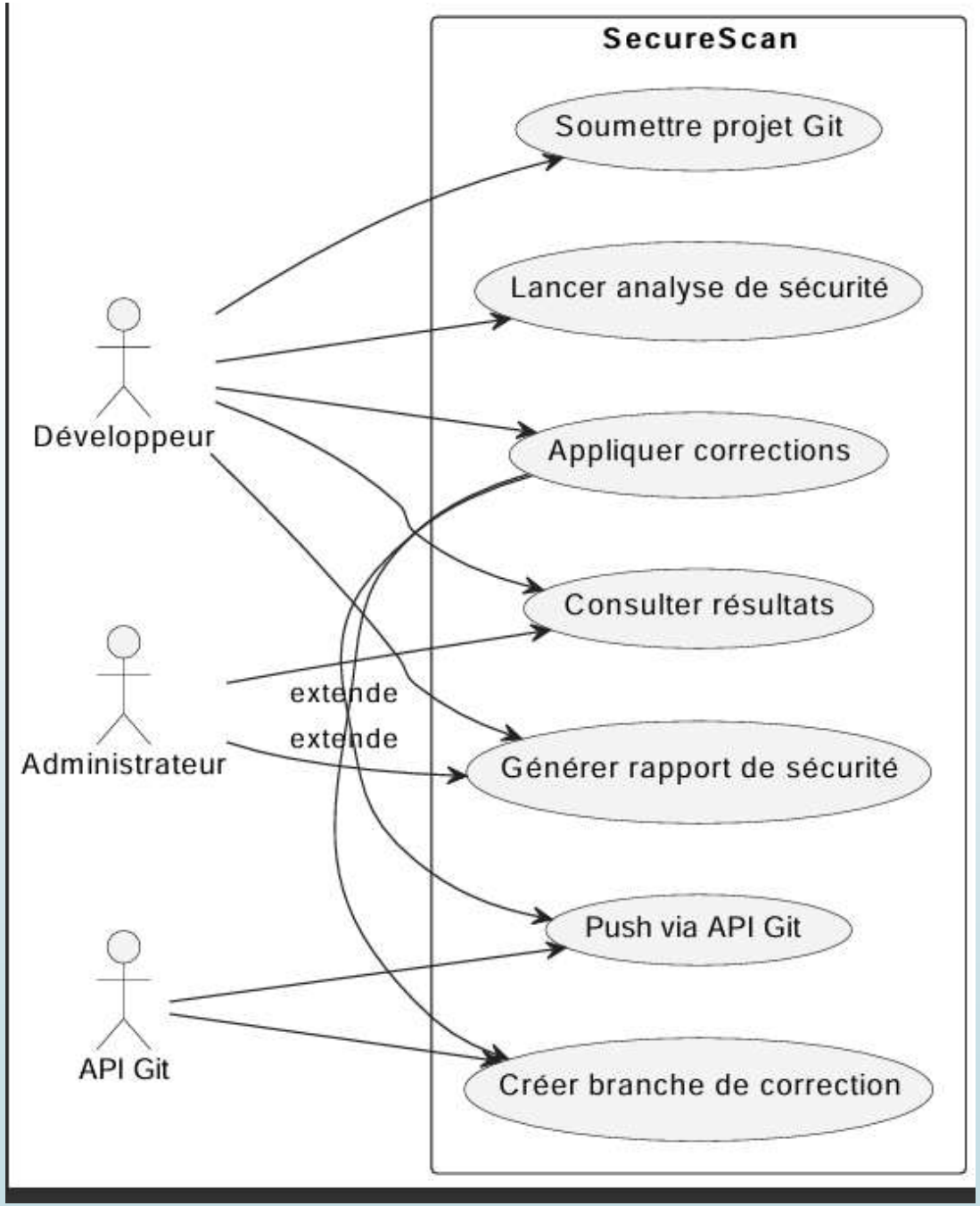

Utilisateur
Front-End
React
HTML
CSS
Back-End
node.js
Express
Analyse
Semgrep
ESlint
npm audit
BDD
Front-End
Affichage

Diagramme de cas d'utilisation



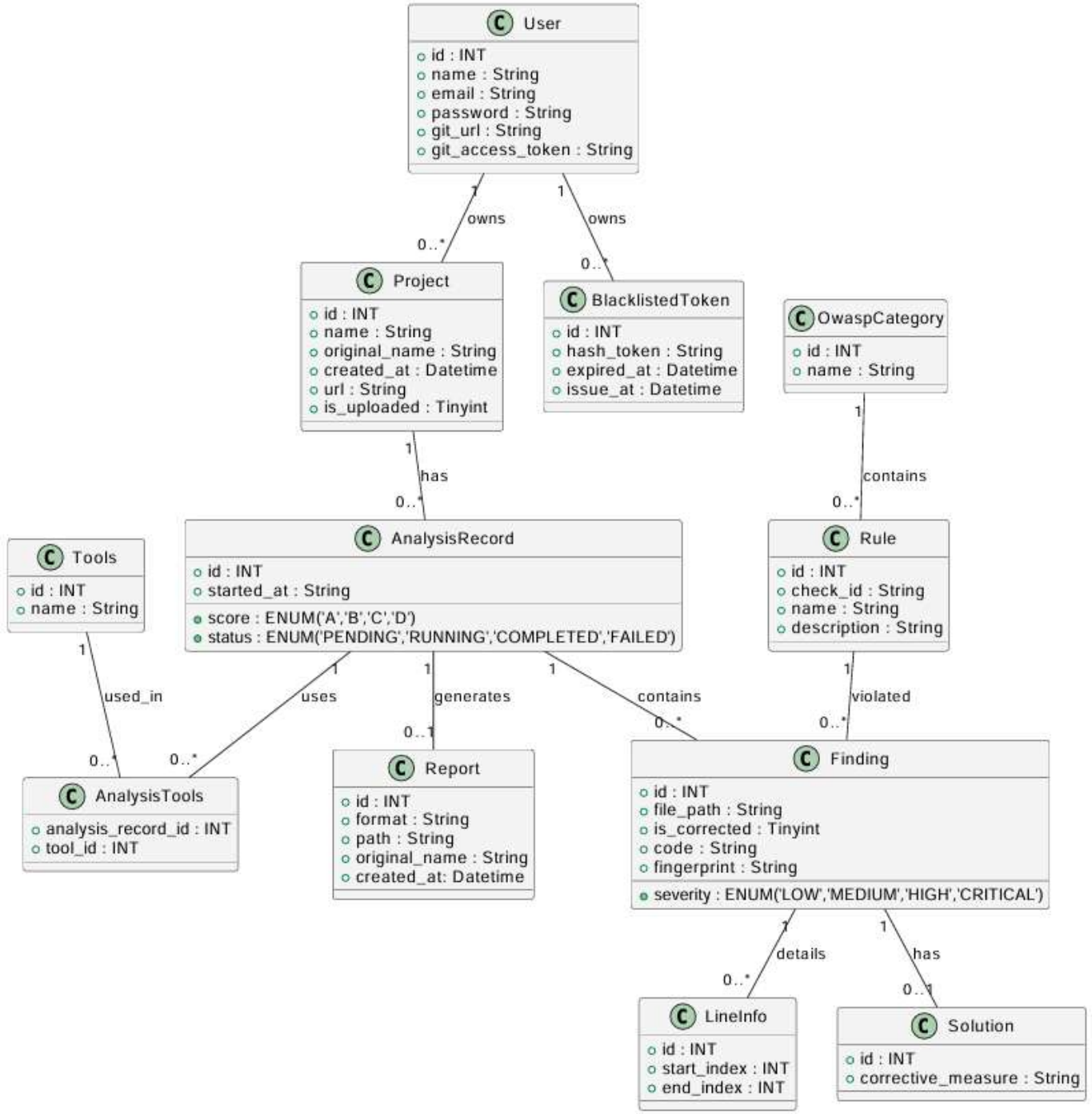
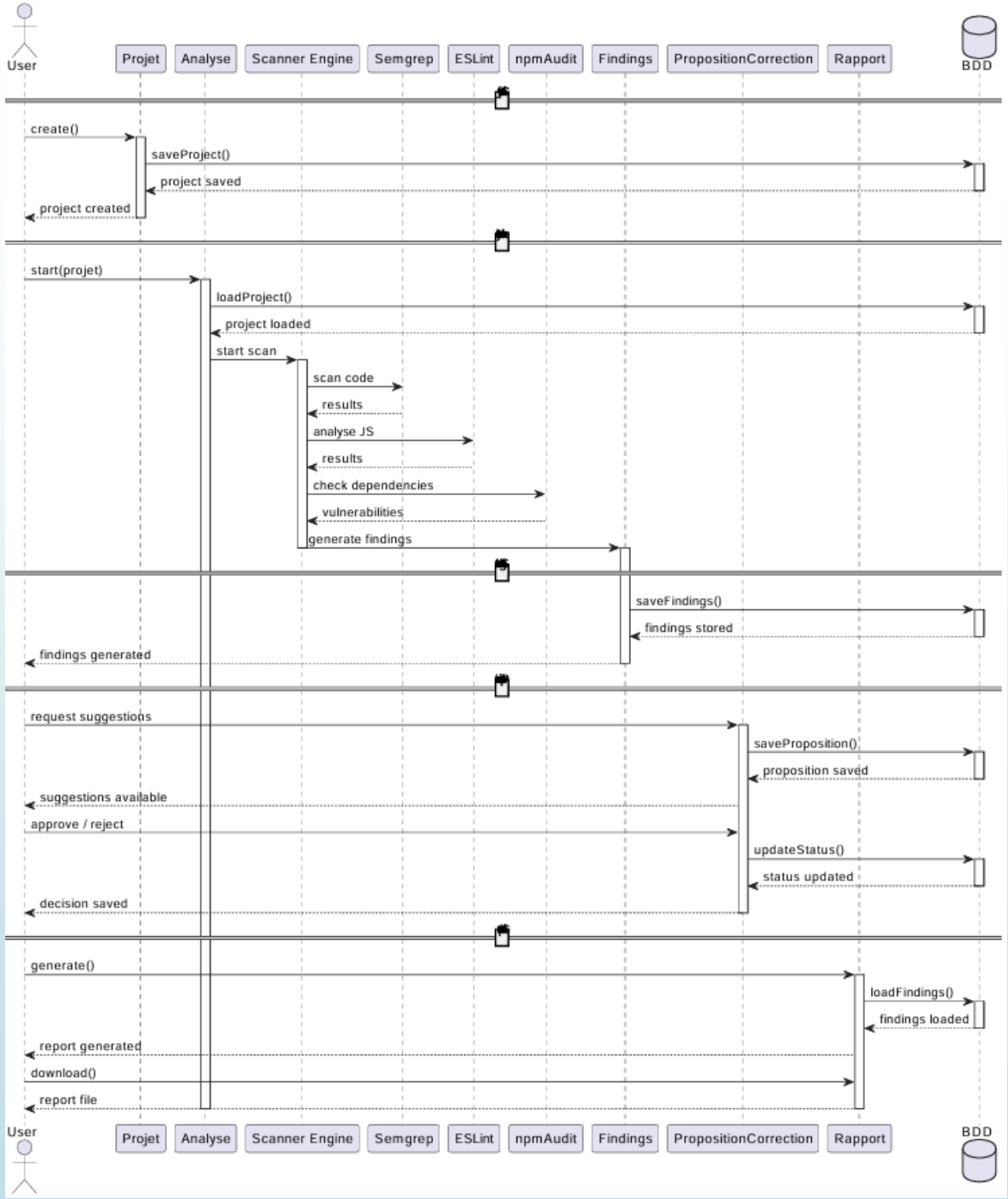


Diagramme de classe

Diagramme de séquence



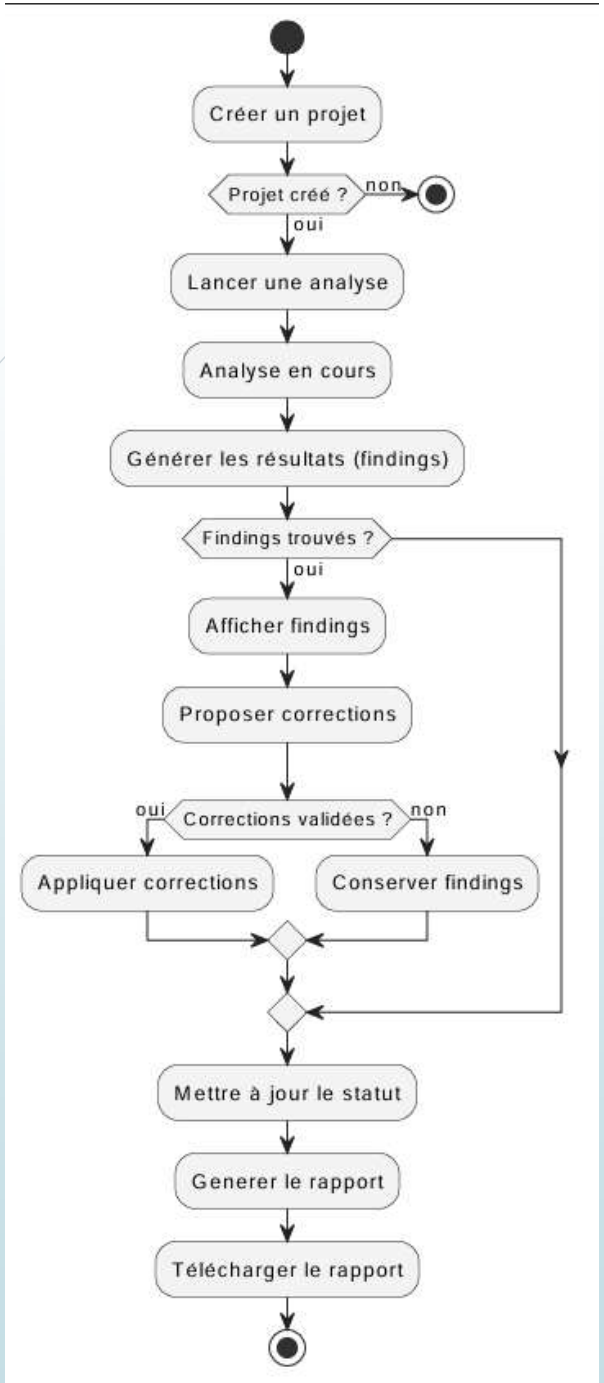
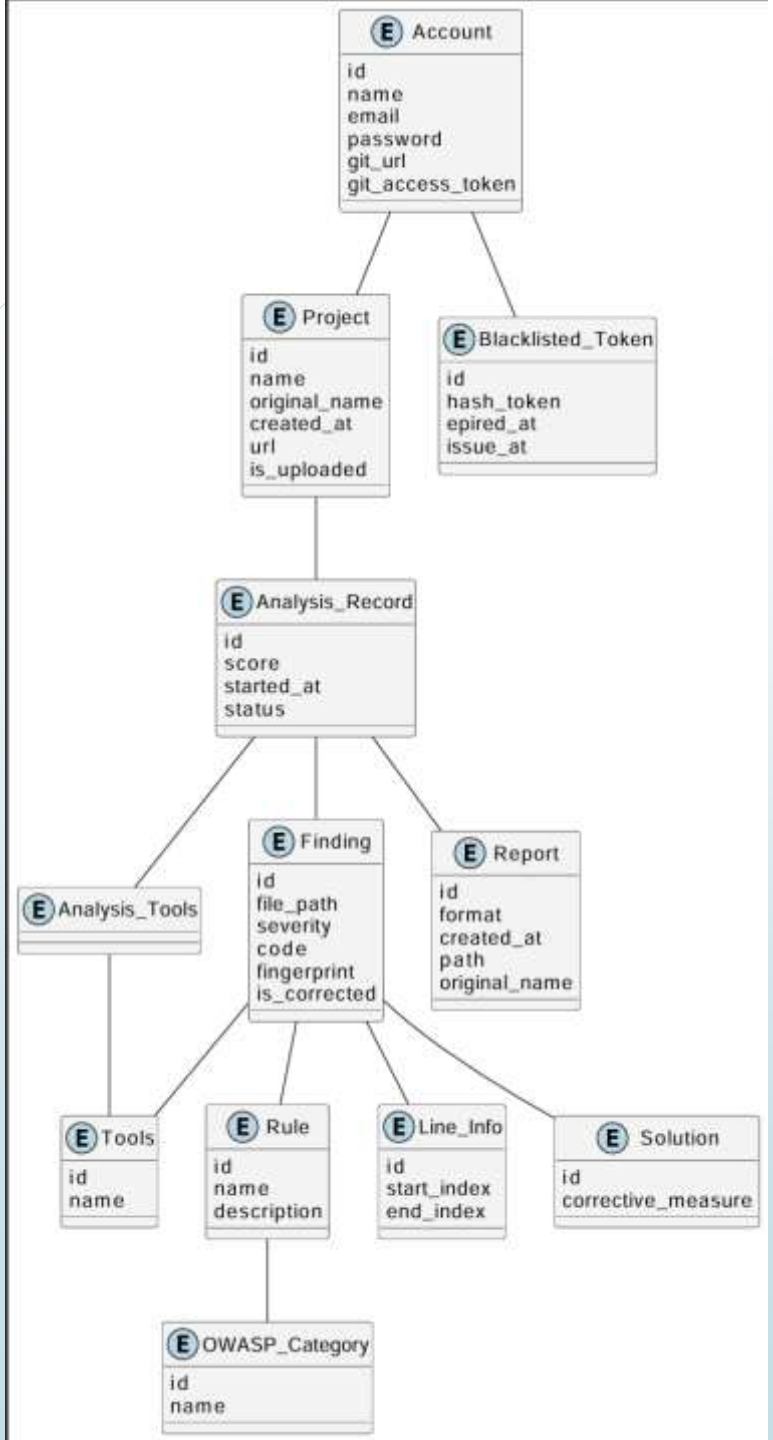
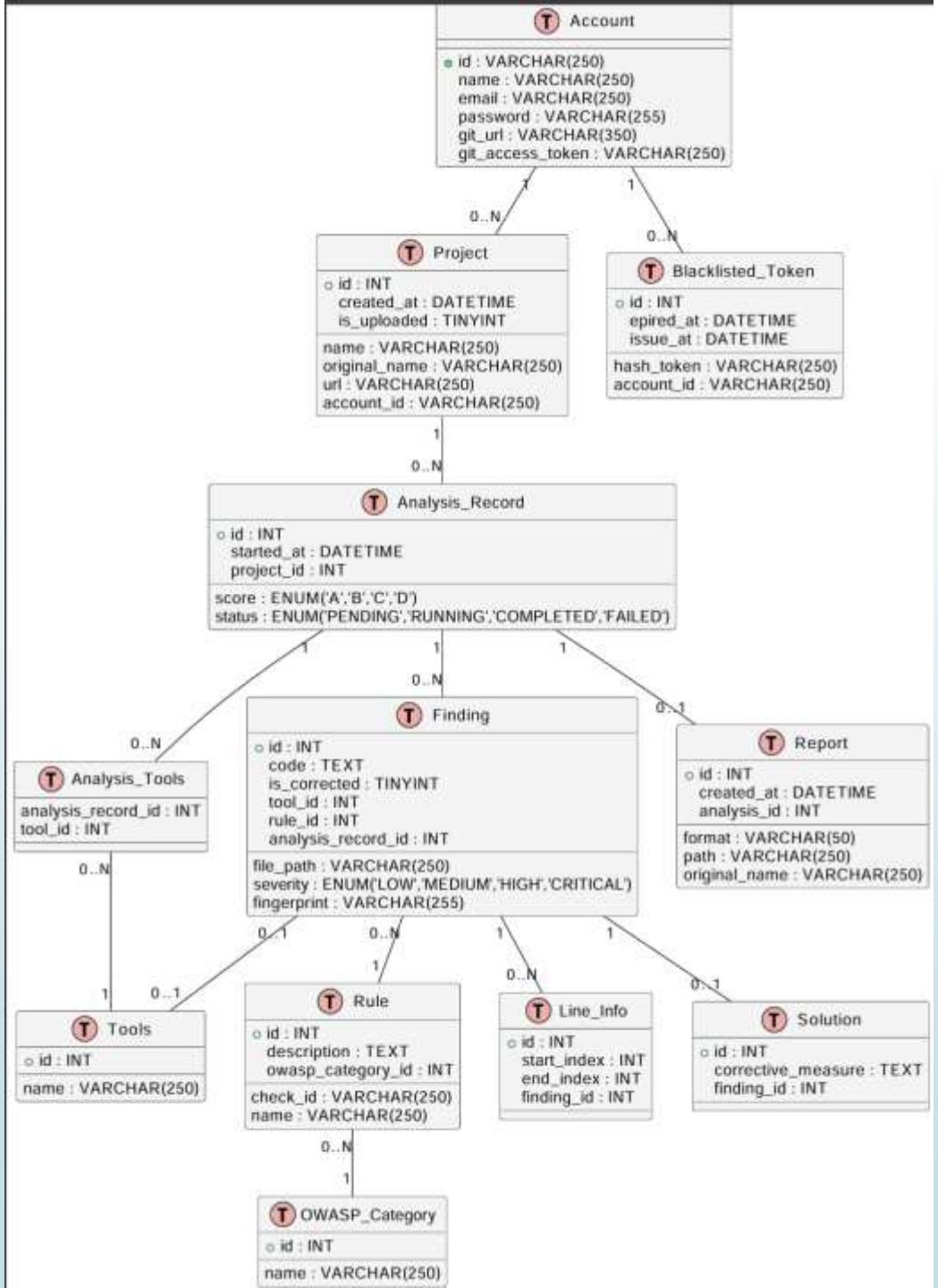


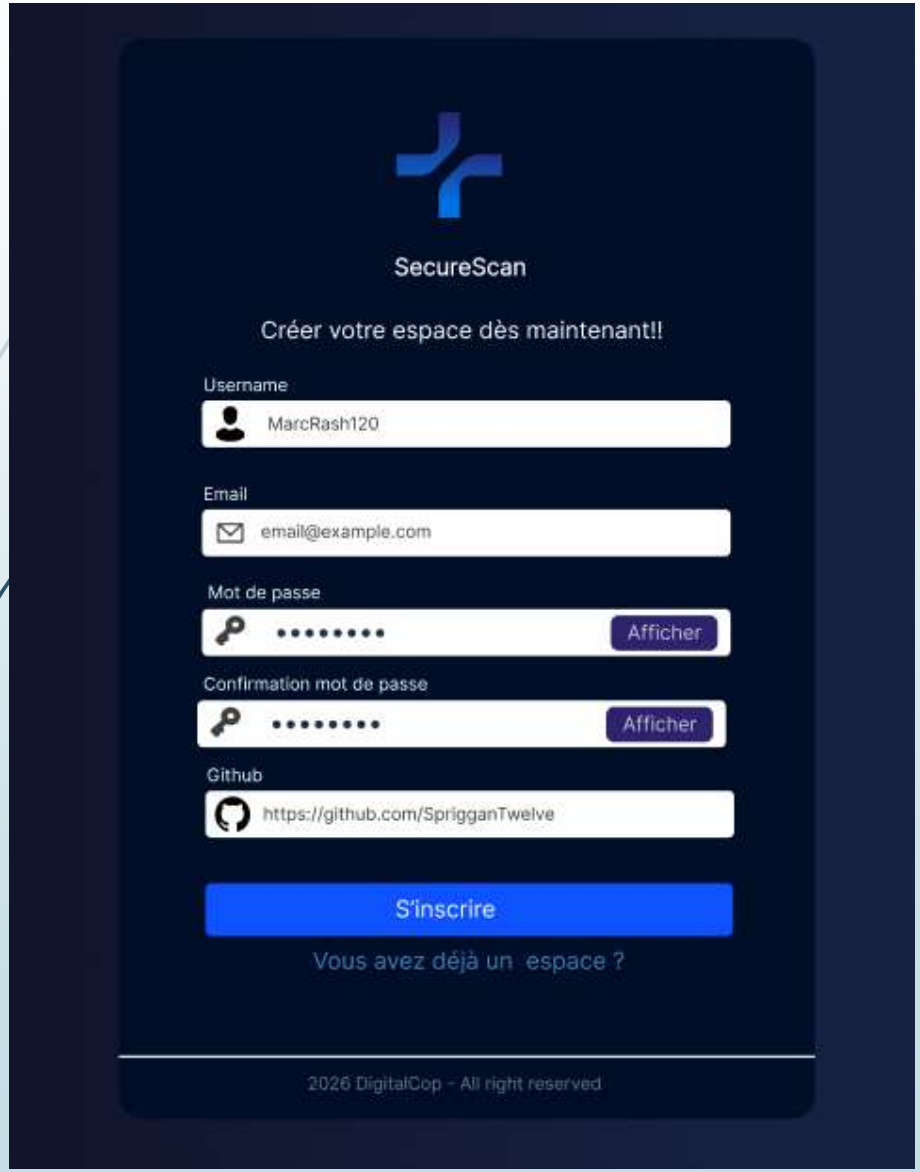
Diagramme d'activité

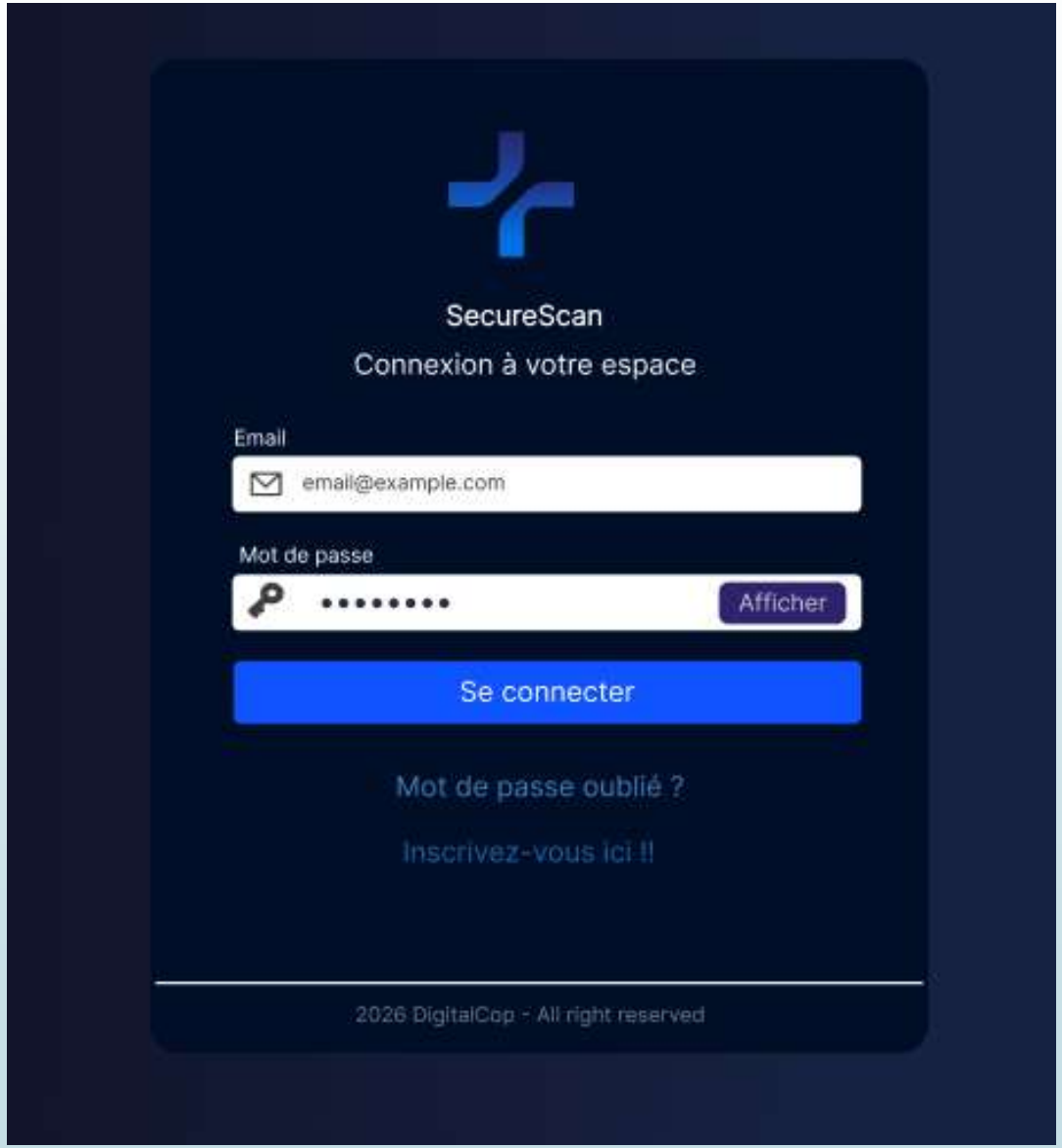
MCD & MLD

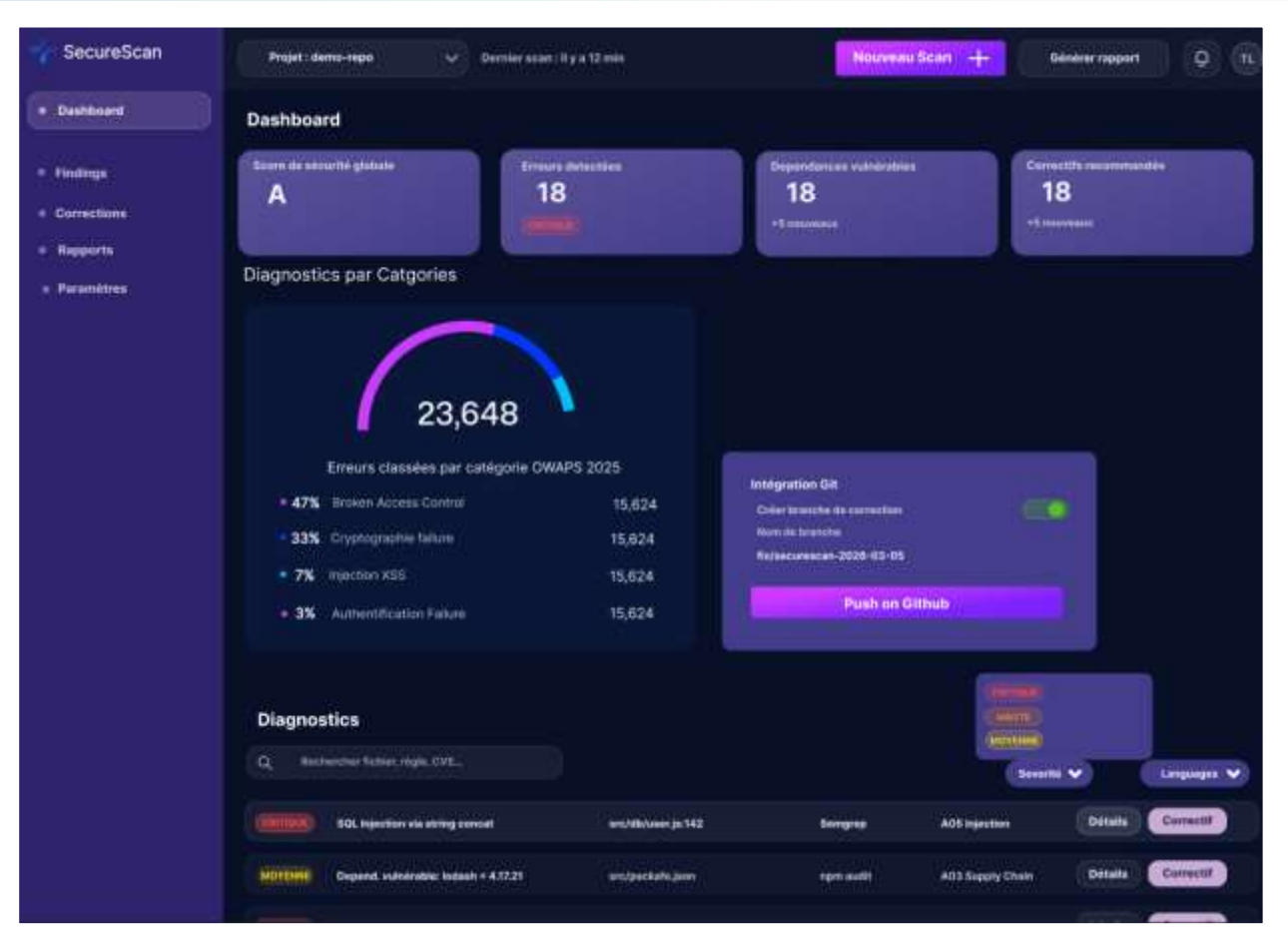

Account
id
name
email
password
git_url
git_access_token
Project
id
name
original_name
created_at
url
is_uploaded
Blacklisted_Token
id
hash_token
epired_at
issue_at
Analysis_Record
id
score
started_at
status
Analysis_Tools
Finding
id
file_path
severity
code
fingerprint
is_corrected
Report
id
format
created_at
path
original_name
Tools
id
name
Rule
id
name
description
Line_Info
id
start_index
end_index
Solution
id
corrective_measure
OWASP_Category
id
name

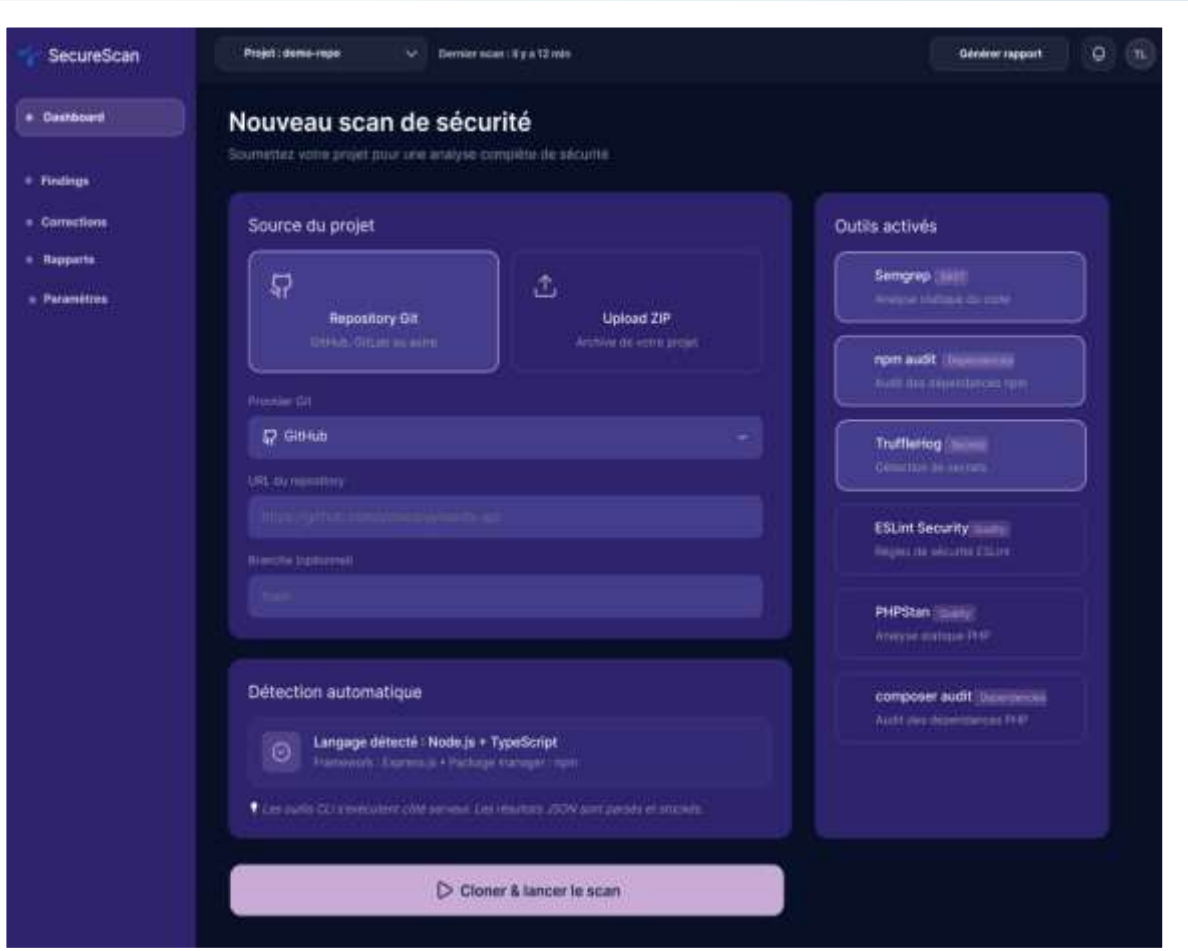

Account
id : VARCHAR(250)
name : VARCHAR(250)
email : VARCHAR(250)
password : VARCHAR(255)
git_url : VARCHAR(350)
git_access_token : VARCHAR(250)
Project
id : INT
created_at : DATETIME
is_uploaded : TINYINT
name : VARCHAR(250)
original_name : VARCHAR(250)
url : VARCHAR(250)
account_id : VARCHAR(250)
Blacklisted_Token
id : INT
epired_at : DATETIME
issue_at : DATETIME
hash_token : VARCHAR(250)
account_id : VARCHAR(250)
Analysis_Record
id : INT
started_at : DATETIME
project_id : INT
score : ENUM('A','B','C','D')
status : ENUM('PENDING','RUNNING','COMPLETED','FAILED')
Analysis_Tools
analysis_record_id : INT
tool_id : INT
Finding
id : INT
code : TEXT
is_corrected : TINYINT
tool_id : INT
rule_id : INT
analysis_record_id : INT
file_path : VARCHAR(250)
severity : ENUM('LOW','MEDIUM','HIGH','CRITICAL')
fingerprint : VARCHAR(255)
Report
id : INT
created_at : DATETIME
analysis_id : INT
format : VARCHAR(50)
path : VARCHAR(250)
original_name : VARCHAR(250)
Tools
id : INT
name : VARCHAR(250)
Rule
id : INT
description : TEXT
owasp_category_id : INT
check_id : VARCHAR(250)
name : VARCHAR(250)
Line_Info
id : INT
start_index : INT
end_index : INT
finding_id : INT
Solution
id : INT
corrective_measure : TEXT
finding_id : INT
OWASP_Category
id : INT
name : VARCHAR(250)

Design/ Interface utilisateur

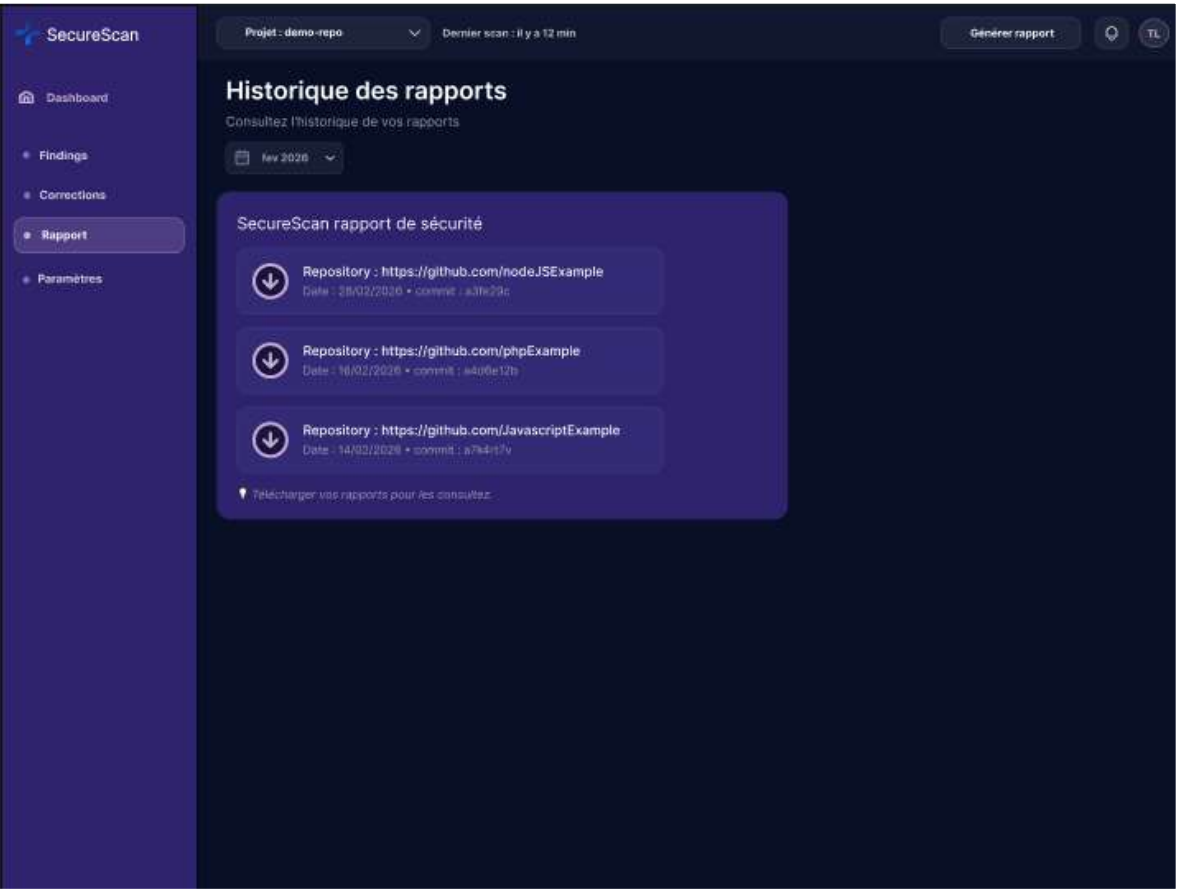


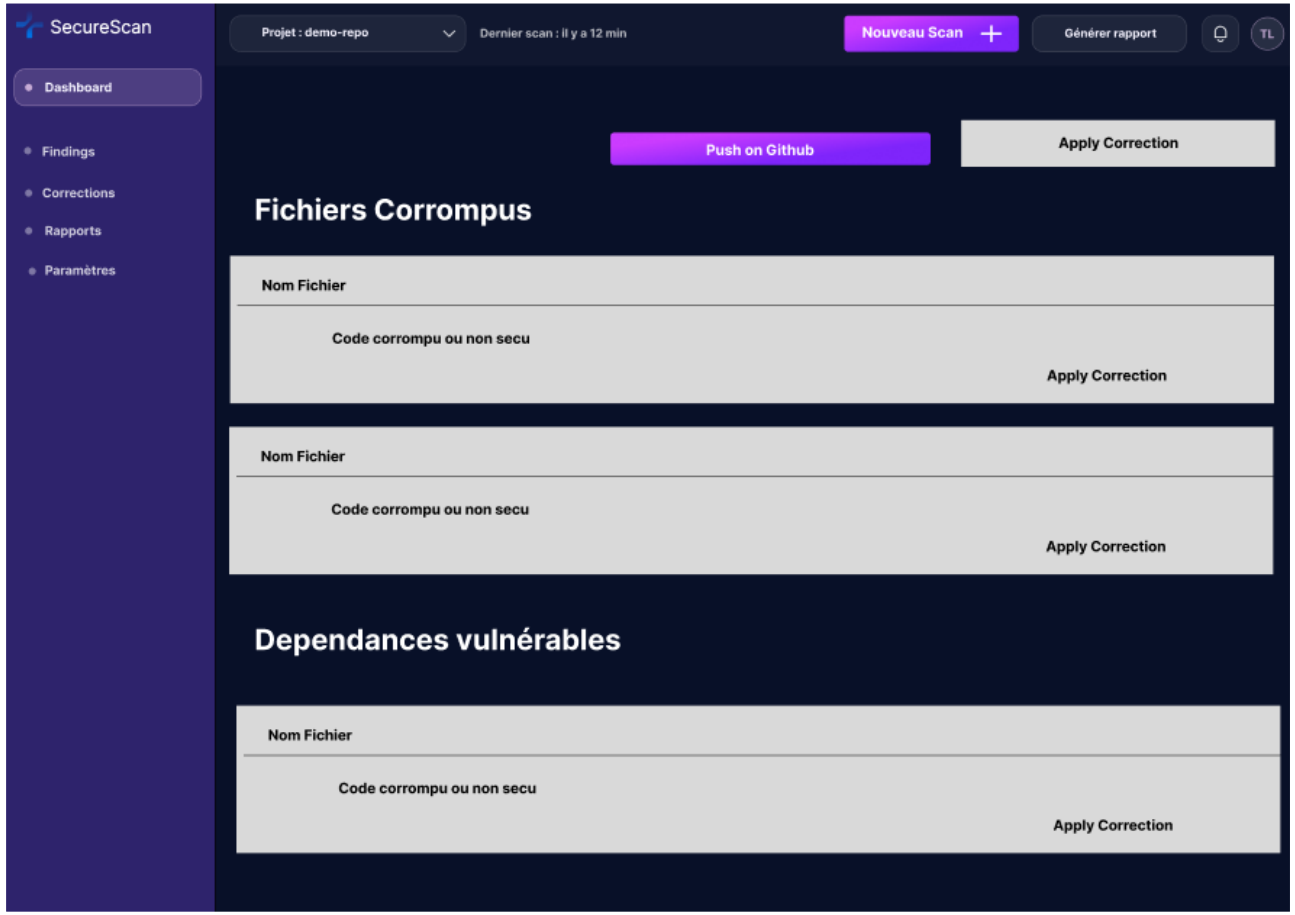




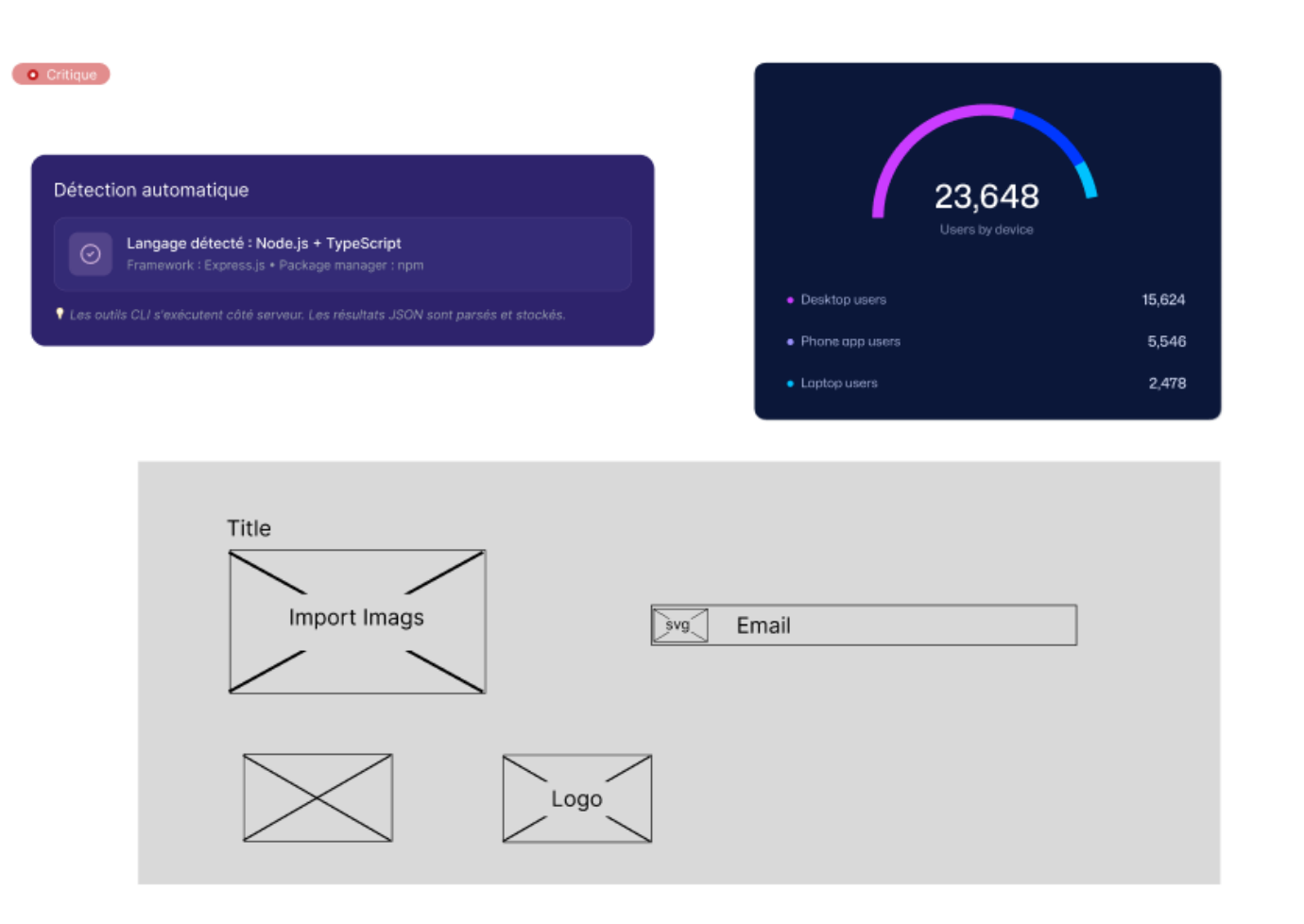


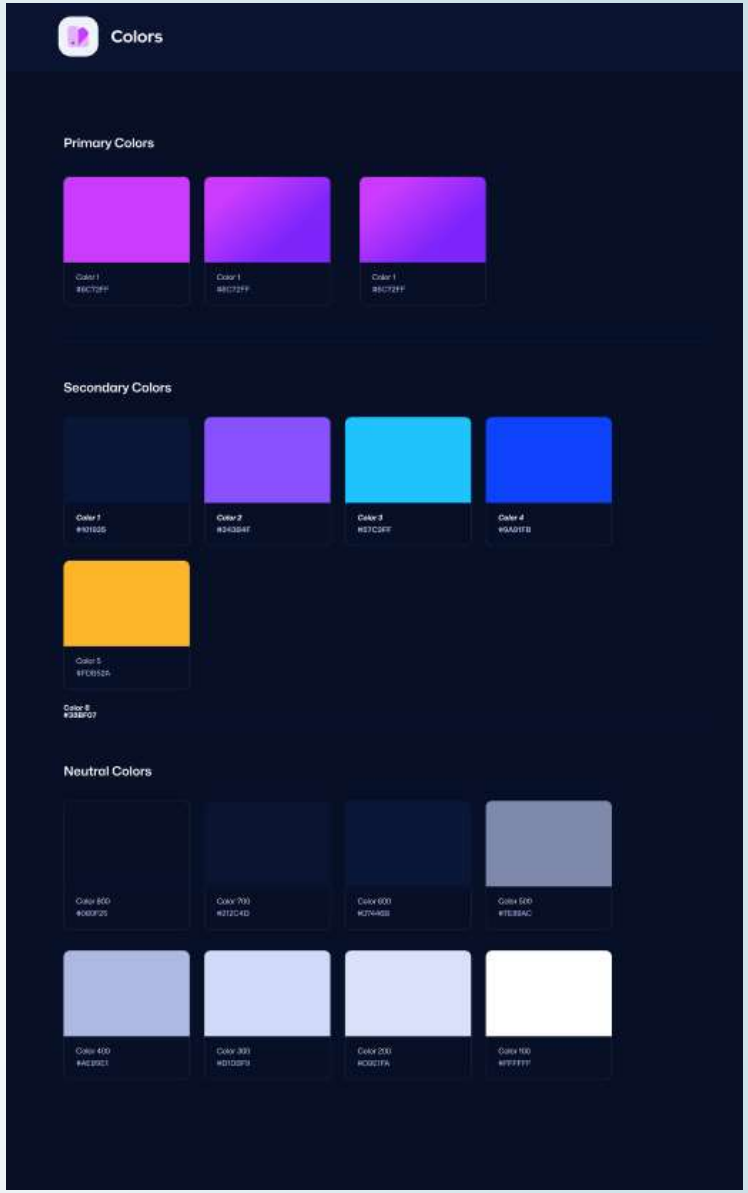
https://www.figma.com/design/jO5qssmz1NU7HGbo9ysCCd/SecureScan?node-id=4-2&t=fdaaofYqdOIzqb0q-1





https://www.figma.com/design/jO5qssmz1NU7HGbo9ysCCd/SecureScan?node-id=4-2&t=fdaaofYqdOIzqb0q-1





https://www.figma.com/design/jO5qssmz1NU7HGbo9ysCCd/SecureScan?node-id=4-2&t=fdaaofYqdOIzqb0q-1

Intégration des outils de sécurité

Semgrep

Analyse statique du code source pour détecter des patterns vulnérables

Npm audit

Scan des dépendances pour identifier les vulnérabilités

ESLint Security

Analyse statique du code source pour détecter des patterns vulnérables

Mapping OWASP Top 10

Rang	Catégorie	Exemples de détection
A01	Broken Access Control	IDOR, CORS mal configuré, escalade de privilèges
A02	Security Misconfiguration	Headers manquants, debug actif, config par défaut
A03	Software Supply Chain Failures	Dépendances vulnérables, packages malveillants
A04	Cryptographic Failures	Mots de passe en clair, algorithmes obsolètes
A05	Injection	SQL injection, XSS, command injection
A06	Insecure Design	Absence de validation, flux non sécurisés
A07	Authentication Failures	Brute force, sessions non invalidesées
A08	Software/Data Integrity Failures	CI/CD non sécurisé, désérialisation
A09	Logging & Alerting Failures	Logs absents, pas d'alertes sur erreurs
A10	Mishandling of Exceptional Conditions	Erreurs non gérées, fail-open, stack traces exposées

SecureScan classe chaque vulnérabilité selon le référentiel OWASP Top 10 et sa sévérité (critique, haute, moyenne, basse). Le dashboard montre la répartition par catégorie et par niveau de risque, ce qui permet à l'utilisateur de voir rapidement quelles vulnérabilités corriger en priorité.

Merci de votre attention.

Zouayobo DALI
Thibault LECHANTRE
Mattéo LECOHIER
Krishmini KULAKRISHNA